



Scry 软件功能设计文档

Scry 安全智能运维平台

文档版本：1.0.0

产品名称：Scry 安全智能运维平台

对应赛题：第十五届中国软件杯 A2“面向麒麟操作系统的安全智能运维 Agent 设计与实现”

目标平台：麒麟高级服务器操作系统 V11、LoongArch64

编制日期：2026-07-20

测试与验证环境说明：已在麒麟高级服务器操作系统 V11 + 龙芯（LoongArch）平台完成软件适应性测试，确保 Scry 可以在该环境下完美运行。考虑到麒麟-龙芯实体环境的持续使用成本，除适应性测试外，现阶段其他功能与性能测试主要在 macOS 开发环境及其中运行的麒麟系统虚拟机中开展；后续将在麒麟-龙芯平台补充相应测试。

1. 设计目标

Scry 的设计目标是在企业 Linux 和麒麟服务器场景中，让大模型能够使用实时运维工具完成诊断与受控操作，同时把身份、权限、风险、审批、参数、执行和审计从模型推理中剥离，交给确定性的服务端组件控制。

设计必须满足以下原则：

- 1. 证据先于结论：模型必须先查询事实，再形成根因判断。
- 2. 安全默认拒绝：安全组件不可用、参数不匹配或权限不明确时停止执行。
- 3. 模型不等于权限：模型只能提出工具调用，不能授予自己更高权限。
- 4. 工具而非 Shell：所有 OS 动作通过有 Schema 的工具和固定包装器完成。
- 5. 全链路可追溯：请求、判断、审批、执行和验证共享 traceId。
- 6. 目标平台原生：提供麒麟 V11/LoongArch64 的原生构建和 systemd 部署路径。

2. 总体架构

Scry 采用 B/S 分层架构：



2.1 组件职责

组件	设计职责
Web Console	提供查询、对话、证据、记忆、工作流和安全配置界面
Query Service	复用现有 JWT/RBAC，提供有界遥测、服务、仪表盘和告警查询
Agent Service	组织模型请求、MCP 工具、安全策略、证据、记忆、SSH 和 Loop
OpenTelemetry Collector	接收并转发 OTLP 指标、日志与链路
ClickHouse	大规模遥测存储、过滤、聚合和时间范围查询
PostgreSQL	保存 Mastra Agent/Workflow 运行状态
WASM SQLite	保存设置、对话索引、证据、记忆、插件、主机、策略和审计
scry-ops	在目标主机执行固定只读或经批准的变更包装器

3. 功能模块设计

3.1 Web Console

Web Console 延续现有 React 路由和权限体系，新增以下工作区：

- Agent Workspace：Thread、流式消息、计划、工具状态、A2UI 和检查器。
- Memory Manager：记忆列表、分块预览、来源、关系、状态和维护。
- Workflow Manager：Loop 列表、可视化定义、触发器、运行和恢复。
- Agent Settings：模型、MCP 插件、SSH 主机、工具策略与安全审计。
- Debug Mode Settings：故障场景、信号类型、生成频率和清理。

前端只负责交互和状态展示。角色、组织、安全裁决、审批和参数校验必须由服务端再次执行。

3.2 统一可观测与 OS 感知

持续感知由 OpenTelemetry 与基础设施遥测完成；即时感知由 `scry-ops` 固定巡检完成。两条路径使用统一时间窗口并进入证据系统：

告警/用户症状

-> 确定服务、主机和时间范围

-> 并行查询指标、日志、Trace、主机状态

-> 规范化为 Series/Table/SSH Result

-> 脱敏、评分、持久化为证据

-> Agent 组织根因链

Agent 不直接访问 ClickHouse；它使用当前用户 JWT 调用 Query Service，使既有 RBAC 始终有效。所有查询必须限制时间范围、返回行数、超时和结果字节数。

3.3 Agent 运行时

Agent 支持 `diagnose`、`plan`、`operate` 三种模式：

- `diagnose`：只读取证和根因分析。
- `plan`：输出步骤、依赖、风险与验证条件，不执行变更。
- `operate`：允许提出受控操作，但必须通过服务端策略、审批和包装器。

系统 Prompt 分层包含角色边界、安全要求、工具使用规则、证据约束和输出格式。用户消息、附件和工具数据放入不可信数据边界，不得覆盖系统规则。

复杂请求先发布 2 至 6 步计划。模型调用采用流式响应；工具状态与消息持久化，使页面刷新后能够恢复 Thread。外部模型超时、取消或失败时，系统保留已采集证据并返回明确错误。

3.4 MCP 设计

Agent Service 内置 MCP Streamable HTTP Server。工具按领域分组：

工具组	主要工具
计划	<code>publishPlan</code>
可观测	<code>listServices</code> 、 <code>listAlerts</code> 、 <code>listDashboards</code> 、 <code>querySignals</code>
安全	<code>evaluateSecurityIntent</code>
SSH	<code>sshListHosts</code> 、 <code>sshReadonlyInspect</code> 、 <code>sshExecuteCommand</code>
证据	<code>listEvidence</code> 、 <code>getEvidenceChain</code>
记忆	<code>searchMemory</code> 、 <code>remember</code> 、 <code>inspectMemory</code> 、 <code>maintainMemory</code> 、 <code>forgetMemory</code>

上述名称是 MCP Server 在 `tools/list` 中发布的运行时名称；进入 Agent 后增加 `scry_` 前缀。每个工具具有 Zod/JSON Schema 输入输出约束，输入对象通过 `additionalProperties=false` 拒绝未声明字段。Schema 为每个字段描述业务含义、来源、枚举、范围和调用示例；模型直接传一个参数对象，无参数工具传 `{}`，不得添加 `args`、`input`、`payload` 或底层 HTTP 包装层。为兼容自定义 OpenAI Responses 端点，工具不发送 `provider strict` 扩展字段，服务端 Schema 校验保持启用。

内置 MCP 初始化指令包含统一调用协议，Agent 同时从受版本控制的协议常量构建系统提示。MCP Client 保持 Server Instructions 自动转发关闭，以兼容自定义模型端点并避免第三方指令提升权限。远程 MCP 插件记录名称、URL、启用状态、超时和加密认证头；禁止内嵌 URL 凭证，禁止覆盖 Host、Content-Length、Connection 和 Transfer-Encoding 等传输头。插件调用不转发 Scry JWT，并对单插件错误进行隔离。

3.5 安全护栏设计

安全链分为输入、决策、工具和执行四层：

```

输入层: NFKC -> 零宽字符清理 -> Prompt Injection 规则
决策层: 意图分类 -> 风险分 -> allow/approval/deny
工具层: Schema -> RBAC -> 策略 -> 参数哈希 -> 命令复检
执行层: scry-ops -> ForceCommand -> sudoers -> 服务白名单 -> 验证
  
```

3.5.1 Prompt Injection 检测

规则覆盖指令覆盖、提示词/凭证提取、安全绕过、角色混淆、不可信工具输出提权和编码载荷。文本先执行 NFKC 归一化、零宽字符删除和空白合并，最大检查长度 200,000 字符。累计风险分达到 50 视为检测命中；风险分达到 60 或涉及提权、秘密读取时策略拒绝。

3.5.2 意图与策略

意图分类输出 `observe`、`diagnose`、`change`、`privilege-escalation`、`secret-access` 或 `unknown`。只读请求允许；变更和操作模式要求审批；提权、秘密读取和高风险注入拒绝。

3.5.3 命令风险复检

命令分析器执行词法解析，拒绝：

- `;`、`&&`、`||`、管道、反引号、`$()`、重定向和换行。
- `bash`、`sh`、`sudo`、`su`、`python`、`node`、`nc` 等解释器或提权程序。
- `rm -rf`、`mkfs`、`wipefs`、`dd`、关机、重启、清空防火墙、用户和密码修改。
- 未调用 `/opt/scry-ops/bin/scry-*` 的任意命令。

唯一例外是 `sudo -n` 加精确 `scry-ops` 包装器路径，且仍返回 `require-approval`。

3.6 最小权限执行设计

受管主机创建固定 `scry-ops` 账户，只允许公钥认证。`sshd` 使用 `ForceCommand` 将全部请求交给 `scry-dispatch`，并禁用 TTY、端口转发和隧道。

只读包装器覆盖系统概况、磁盘、内存、失败服务、监听端口和近期错误。变更包装器只能操作 `/etc/scry-ops/allowed-services` 中的 `systemd` 服务或明确登记的动作。包装器和配置由 `root:root` 持有，运行账户不可写；`sudoers` 只授权精确路径。

执行请求包含 `hostId`、`toolId`、`commandId`、参数和 `traceId`。审批记录绑定这些字段的哈希；任何参数变化都会重新触发策略。执行结束记录退出码、耗时、输出字节数，并调用只读工具验证状态。

3.7 证据系统设计

证据对象独立于前端消息解析，核心字段包括：

- threadId、orgId、userId、traceId、messageId。
- sourceType、sourceName、title、summary、脱敏内容与内容哈希。
- confidence、relevance、评分因子。
- active、accepted、rejected、suspended 状态和选择标记。
- 证据关系、操作历史与修订记录。

置信度由来源可靠性、数据质量、新鲜度、执行完整性和直接性确定；关联度由词项匹配和来源线索确定。命中注入规则的工具、附件或网页证据自动设为 `suspended` 并取消选择。

证据关系包括 `same_trace`、`corroborates`、`related` 和 `derived_from`。证据约束重答只使用用户选定且未被驳回或挂起的证据，不调用新工具，每个关键判断引用证据 ID。

3.8 TopoMem 运行记忆设计

记忆类型包括服务画像、Runbook、告警、变更、因果观察、故障模式、处置和验证记录。内容按稳定边界分块并保留来源、关系和服务拓扑。

TopoMem 分两阶段：

1. Trace-guided Walk：从症状服务沿异常调用边遍历到候选根服务。
2. Signature Rerank：使用日志字段、Span 标签、错误码和告警词项在候选服务记忆中重排。

在 Trace 缺失时回退到词法/稠密检索；在冲突 Trace 下可保留多路径候选。该设计解决症状层和根因层使用不同运维词汇时，平面文本检索无法连接服务的问题。

根目录 `main.pdf` 的受控评测表明：TopoMem-Walk 的 Root Hit@5 为 0.927，完整 TopoMem 为 0.964、MRR@5 为 0.655；多路径版本在陈旧高错误分支和并发故障分支上均达到 0.919。完整数据集、置信区间、鲁棒性、延迟和下游 Agent 结果统一收录于《软件性能（核心指标）测试报告》。

3.9 Loop 自动化设计

Loop 定义支持：普通步骤、MCP 工具、分析、安全检查、审批、操作、验证、条件、并行、`while`、`until` 和 `foreach`。

结构约束：最多 100 个节点；控制结构最多嵌套 5 层；循环最多 50 次/项；并行分支 2 至 6；`foreach` 并发 1 至 10；全部节点 ID 唯一。

运行入口统一进入 Dispatcher。Dispatcher 应用实例、组织和 Loop 三级并发控制，支持 `allow`、`forbid`、`replace` 策略。Worker 使用租约、检查点和重试；恢复 Worker 只回收租约过期且未完成的 Run，跳过已有完成事件的步骤。

4. 关键流程设计

4.1 只读诊断流程

用户问题

- > JWT/RBAC
- > 注入扫描与意图分类
- > 发布计划
- > 并行调用可观测/OS 工具
- > 结果脱敏与证据评分
- > TopoMem 检索
- > 根因综合与验证建议
- > 审计落库

4.2 受控变更流程

变更请求

- > 输入安全检查
- > 生成计划和风险说明
- > 读取变更前状态
- > 选择预配置操作 ID
- > RBAC/策略/命令复检
- > 审批绑定参数哈希
- > scry-ops 包装器执行
- > 重新读取状态和告警
- > 保存执行与验证证据

4.3 外部证据注入流程

MCP/SSH/附件内容

- > 不可信边界
- > 归一化与注入检测
- > 命中: suspended + 取消选择 + 审计
- > 未命中: 脱敏、限长、评分、入库

5. 数据库设计

WASM SQLite 使用 `scry_` 前缀表保存领域数据:

数据域	主要表
对话	scry_agent_threads、scry_agent_ui_messages
证据	scry_evidence_items、relations、actions、revisions
记忆	scry_memory_items、chunks、sources、relations、actions、topology_edges、retrieval_runs
插件与安全	scry_mcp_servers、scry_security_audit_events
SSH	scry_ssh_hosts、scry_tool_policies、scry_ssh_audit_logs
Loop	scry_workflows、scry_workflow_runs 及版本/事件数据

秘密字段使用主密钥加密；内容通过组织、用户、Thread 和 Trace 建立索引。证据以 threadId、traceId、sourceName 和 contentHash 去重。

6. API 设计

Agent Service 主要接口：

- /health：服务存活检查。
- /mcp：MCP Streamable HTTP。
- /api/chat：Agent 流式对话。
- /api/threads：Thread 创建、列表、读取和删除。
- /api/mcp/tools、/api/mcp/servers：工具目录和远程插件管理。
- /api/settings/model：模型设置和连接测试。
- /api/ssh/hosts、/api/ssh/policies、/api/ssh/audits：主机、策略和执行审计。
- /api/security/audits：统一安全审计。
- /api/memories、/api/memories/search：记忆 CRUD 与检索。
- /api/threads/:threadId/evidence：证据读取、处置和修订。
- /api/workflows、/api/workflow-runs：Loop 定义、运行、流式进度和恢复。

除 /health 外，接口必须验证 JWT。管理员配置接口执行 requireAdmin；资源查询必须附带 orgId 条件。

7. 故障模拟与准确性评测设计

故障目录覆盖健康基线、慢调用、错误突增、数据库连接/清理问题、Redis/Kafka、TLS/DNS、限流、契约错误、OOM、CPU、磁盘、配置漂移、服务不可用、网络暴露、僵尸进程和复合故障。

模拟数据只写入：

- `scry.debug=true`
- `scry.dataset=diagnostic-evaluation`
- `scry.debug.case_id=case-xxx`

公开目录不返回根因标签；真值接口仅管理员可访问。评测器生成 OTLP 数据、等待入库、创建隔离 Thread、要求 Agent 使用工具取证，再按根服务 25、根因 25、证据 20、处置 15、验证 10、安全 5 的权重评分。

8. 部署设计

8.1 开发环境

除已完成的麒麟-龙芯平台软件适应性测试外，其他开发期测试主要在 macOS 研发工作站开展。macOS 通过 Docker Compose 启动 PostgreSQL、ClickHouse、Collector、Query Service、Agent Service、Frontend 和告警组件，并通过其中运行的麒麟系统虚拟机完成日常兼容性验证。统一入口为 Web Console 3301，Agent 4111，Query Service 8080。

8.2 麒麟 V11/LoongArch64

目标机部署不依赖 amd64/arm64 容器镜像：

1. 构建或安装 LoongArch64 Node.js 22。
2. 配置 PostgreSQL 最小权限账户和强密码。
3. 执行 `preflight.sh` 校验架构、系统和依赖。
4. 在目标机原生构建 Query Service、Agent 和 Frontend。
5. 使用 `install-native.sh` 安装 systemd、Nginx 和目录权限。
6. 使用 `acceptance.sh` 校验架构、服务、健康接口和非 root 用户。

Agent 使用纯 JS/WASM SQLite，Query Service 在目标机以 CGO 工具链原生编译。发布包不包含 `node_modules`、测试、缓存、本地数据库和第三方依赖目录，依赖由锁文件从软件源安装。

软件已经在麒麟 V11 + 龙芯（LoongArch）平台完成适应性测试，原生服务、Web 入口和核心功能可在该环境下完美运行。

9. 异常处理与降级

异常	设计行为
外部模型超时	终止生成，保留证据和 traceId，允许重试
MCP 插件超时	隔离该插件，返回结构化错误，不影响其他工具

异常	设计行为
安全工具异常	默认拒绝高风险执行，不静默降级
Query Service 无响应	标记证据缺失，禁止把猜测写成事实
SSH 指纹变化	阻断连接，要求管理员重新确认
审批参数变化	原审批失效，重新裁决和审批
Worker 失联	租约过期后恢复，跳过已完成步骤
调试数据清理	仅按 debug 标识删除，不影响真实遥测

10. 需求到设计追踪

需求域	设计章节	主要实现位置
OS 感知	3.2、3.6	agent-service/src/tools/ssh.ts 、 deploy/scry-ops/
Agent/RCA	3.3、3.8	agent-service/src/agent.ts 、 memory/
MCP	3.4	agent-service/src/mcp/ 、 tools/
安全护栏	3.5、4.2、4.3	agent-service/src/security/
证据审计	3.7、5	evidence.ts 、 security/audit.ts 、 db.ts
Loop	3.9	workflows/compiler.ts 、 workflows/presets.ts
故障评测	7	pkg/query-service/app/debugmode/ 、 tests/accuracy/
麒麟部署	8	deploy/kylin-loong64/

11. 设计结论

Scry 将“模型推理”与“系统授权和执行”明确分离：模型负责任务理解、取证计划和解释，确定性组件负责身份、工具 Schema、风险、审批、参数、权限和审计。该设计直接响应赛题对 OS 感知、MCP、安全过滤、最小权限、链路溯源、自然语言准确性和智能根因分析的要求，并通过证据、TopoMem 和 Loop 提升实用性与创新性。